

Creazione di Gruppi in Windows Server 2022

Progetto S10 / L5 : Gestione utenti e permessi in Active Directory

In questo esercizio ho configurato due gruppi di utenti su un ambiente Windows Server 2022 promosso a Domain Controller del dominio thm.local, con l'obiettivo di applicare il principio del minimo privilegio (least privilege) e dimostrare come la gestione centralizzata tramite Active Directory consenta di assegnare permessi differenziati su file system, esecuzione di programmi, impostazioni di sistema e accesso remoto al server.

Ho creato i gruppi Sviluppatori e MarketingTeam per simulare due profili aziendali con esigenze operative distinte. Al gruppo Sviluppatori ho concesso privilegi tecnici estesi, mentre al gruppo MarketingTeam ho assegnato un perimetro ristretto, coerente con un ruolo non amministrativo. La verifica finale, eseguita con due utenti di prova appartenenti rispettivamente ai due gruppi, ha confermato che la segmentazione funziona come previsto.

Prima di entrare nel merito della creazione dei gruppi ho preparato l'ambiente promuovendo il server a Domain Controller. Questo passaggio non era richiesto esplicitamente dalla traccia, ma l'ho ritenuto necessario perché la gestione di gruppi tramite Active Directory è didatticamente più ricca e operativamente più vicina a uno scenario aziendale reale rispetto alla gestione di gruppi locali.

Sistema operativo	Microsoft Windows Server 2022 Datacenter (build 20348.1006)
Hypervisor	Oracle VirtualBox
Ruolo del server	Domain Controller del dominio thm.local
Indirizzo IP statico	192.168.50.10 / 24
Default gateway	192.168.50.1
DNS preferito	192.168.50.10 (loopback per AD DS)
Utente amministrativo	THM\Administrator
Utenti di prova	THM\h.potter (membro Sviluppatori), THM\d.malfoy (membro MarketingTeam)

La configurazione di rete è stata particolarmente delicata perché un Domain Controller deve risolvere il proprio dominio interrogando il DNS interno. Per questo motivo ho impostato come DNS preferito l'indirizzo IP del server stesso (192.168.50.10): senza questa configurazione, Active Directory non sarebbe in grado di replicare correttamente e tutte le operazioni di join al dominio fallirebbero.

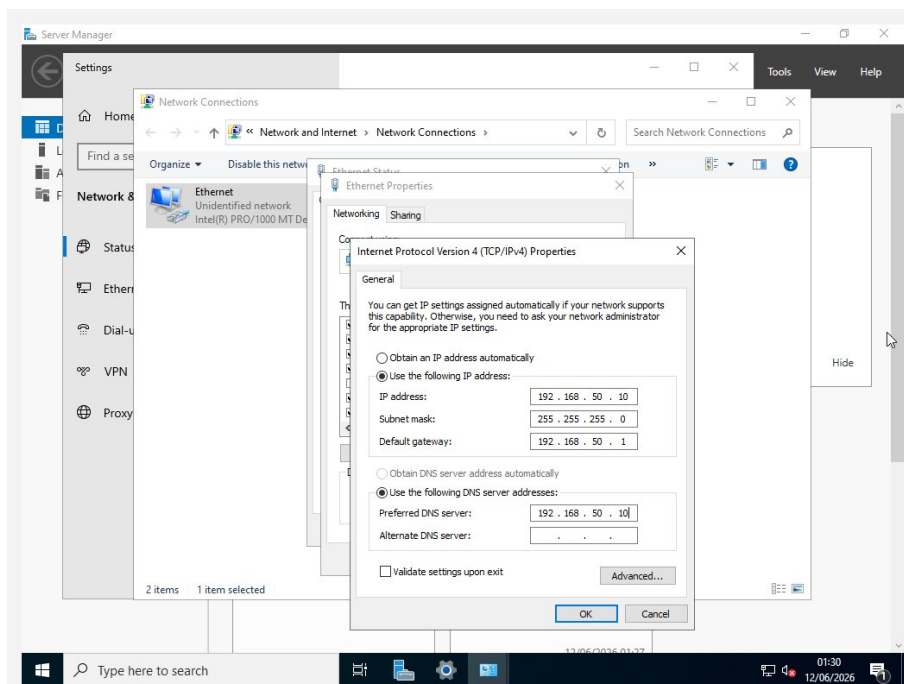


Figura 1: Configurazione IPv4 statica del server prima della promozione a DC.

Dopo aver completato la promozione tramite il wizard di Server Manager, il sistema ha richiesto il riavvio. Al successivo login il prompt di autenticazione mostrava il prefisso di dominio THM\Administrator, conferma visiva che la promozione era andata a buon fine.

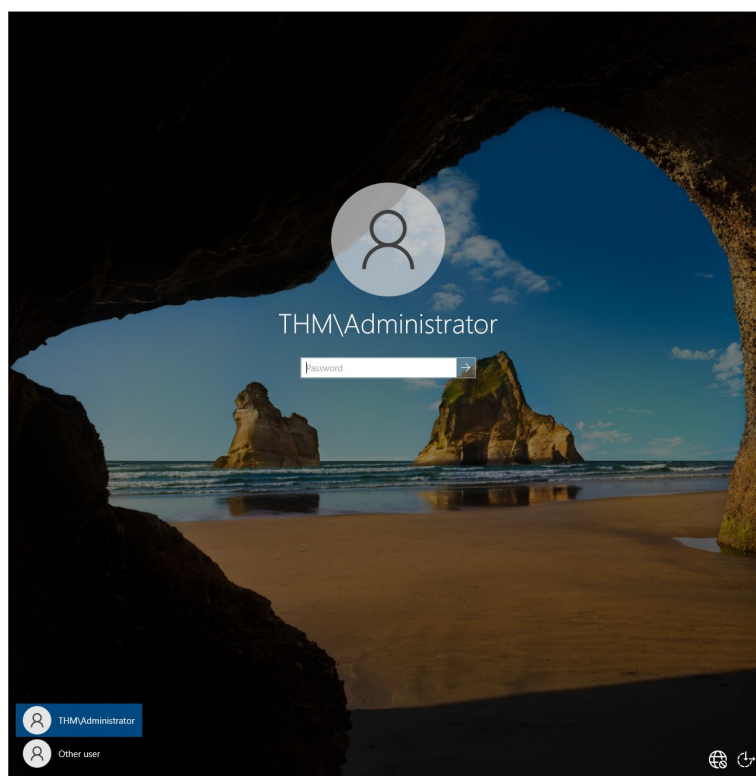


Figura 2: Schermata di login post-promozione: il prefisso THM conferma il dominio attivo.

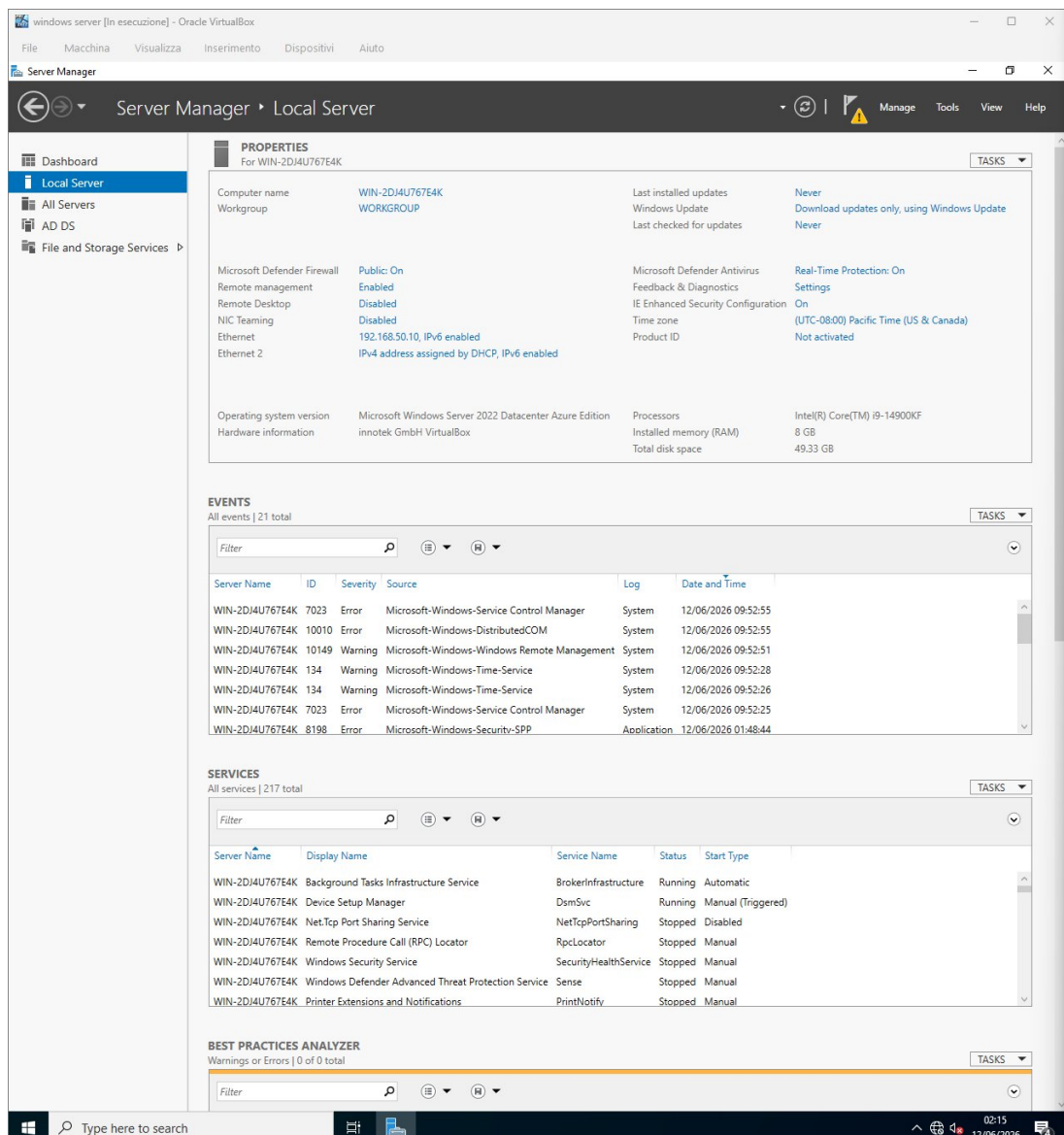


Figura 3: Server Manager dopo la promozione. Il campo Domain mostra thm.local al posto del precedente Workgroup.

Ho aperto la console Active Directory Users and Computers (ADUC) da Server Manager / Tools. Per mantenere ordinata la struttura del dominio ho creato una Organizational Unit dedicata chiamata Lab-Gruppi, dentro la quale ho raccolto sia i gruppi che gli utenti di prova del laboratorio.

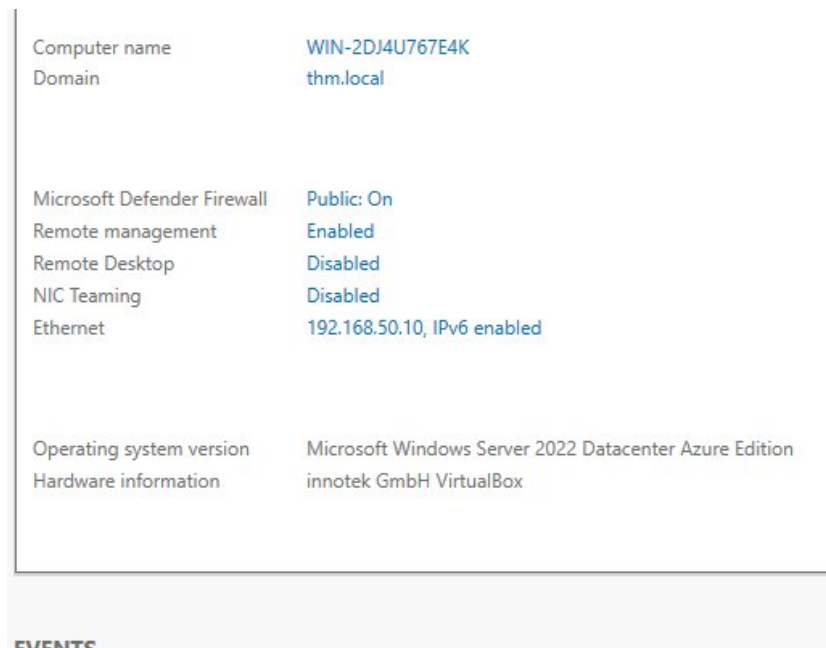


Figura 4: Console ADUC con le OU di default del dominio thm.local appena promosso.

All'interno della OU Lab-Gruppi ho creato i due gruppi richiesti dalla traccia:

Nome gruppo	Tipo	Scope	Funzione simulata
Sviluppatori	Security	Global	Team tecnico con privilegi amministrativi limitati
MarketingTeam	Security	Global	Team non tecnico con perimetro ristretto

Ho scelto il tipo Security e non Distribution perche solo i Security group possono essere referenziati nelle ACL di NTFS e nelle User Rights Assignment delle GPO, ovvero proprio cio che mi serviva per implementare il controllo degli accessi richiesto dall'esercizio. Lo scope Global e adeguato a un singolo dominio: avrei usato Universal solo in caso di foresta multi-dominio.

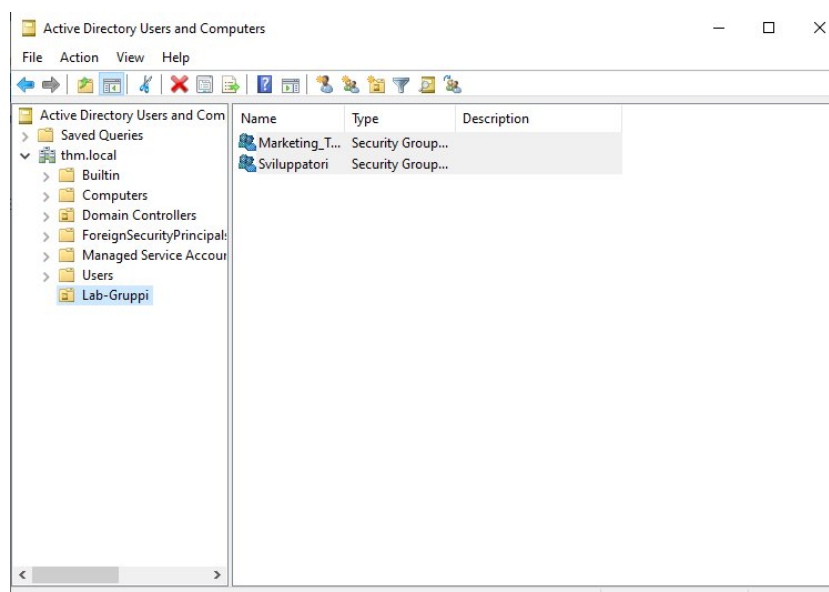


Figura 5: I due gruppi Security creati all'interno della OU Lab-Gruppi.

Subito dopo ho creato i due utenti di prova, h.potter e d.malfoy, e li ho aggiunti rispettivamente al gruppo Sviluppatori e al gruppo MarketingTeam tramite la scheda Members delle proprietà del gruppo. L'utilizzo di nomi tematici e una semplice scelta di leggibilità: l'importante è che a livello tecnico i due

utenti rappresentino due profili aziendali differenti.

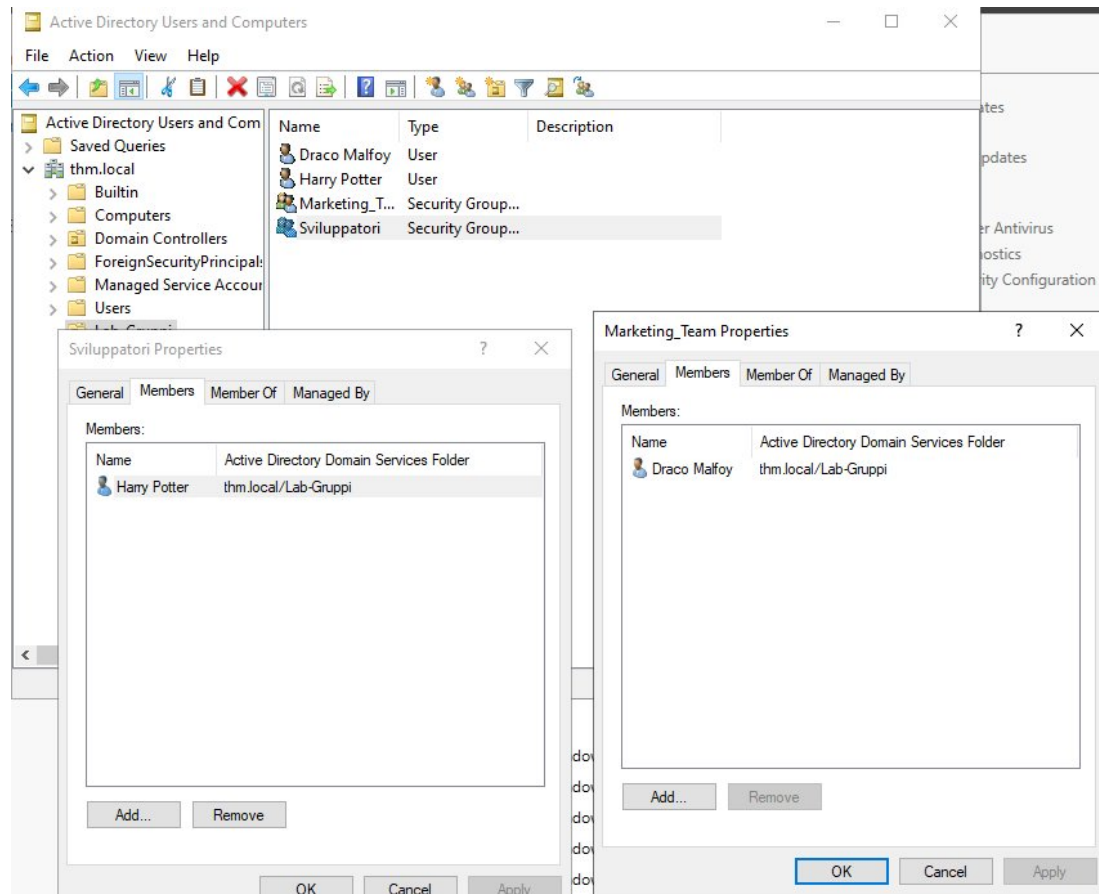


Figura 6: Proprieta dei due gruppi. Harry Potter e membro di Sviluppatori, Draco Malfoy di Marketing_Team.

La traccia richiede di coprire quattro aspetti distinti: accesso a file e cartelle, esecuzione di programmi specifici, modifiche alle impostazioni di sistema, accesso remoto al server. Ho affrontato ogni aspetto con la tecnologia Windows piu appropriata, alternando ACL di NTFS, Group Policy a livello di dominio e gestione del gruppo built-in Remote Desktop Users.

4.1 Accesso a file e cartelle

Ho creato la struttura C:\Dati\Sviluppo e C:\Dati\Marketing. Su ciascuna delle due sottocartelle ho disabilitato l'ereditarieta delle ACL (convertendo i permessi ereditati in permessi espliciti) e ho rimosso il gruppo BUILTIN\Users, lasciando esclusivamente SYSTEM, Administrators e il gruppo di riferimento con permesso Modify. La cartella padre C:\Dati ho invece deciso di lasciarla con i permessi di default: questo perche serve il diritto di traversal (List folder contents) per consentire agli utenti di raggiungere le sottocartelle. Se avessi rimosso Users anche dal container padre, nessuno sarebbe stato in grado di entrare in C:\Dati per arrivare alla propria cartella, neanche chi aveva i permessi a destinazione.

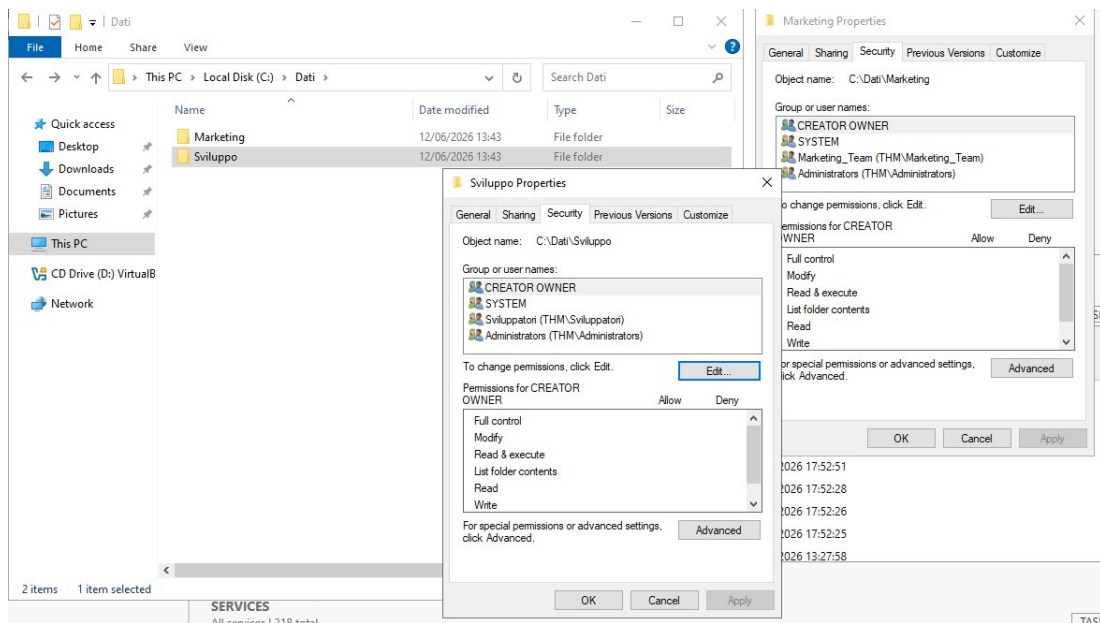


Figura 7: Tab Security delle due cartelle Sviluppo e Marketing dopo la disabilitazione dell'ereditarietà.

Per validare la configurazione in modo compatto ho usato il comando `icacls`. L'output conferma che le sottocartelle non ereditano più dal padre (assenza del flag `I`) e che i gruppi di riferimento hanno permesso `Modify` propagato a sottocartelle e file (flag `OI/CI/M`).

```
Install the latest PowerShell for new features and improvements! https://aka.ms/PowerShellLatest

PS C:\Users\Administrator> icacls C:\Dati
>> icacls C:\Dati\Sviluppo
>> icacls C:\Dati\Marketing
C:\Dati NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)
        BUILTIN\Administrators:(I)(OI)(CI)(F)
        BUILTIN\Users:(I)(OI)(CI)(RX)
        BUILTIN\Users:(I)(CI)(AD)
        BUILTIN\Users:(I)(CI)(WD)
        CREATOR OWNER:(I)(OI)(CI)(IO)(F)

Successfully processed 1 files; Failed processing 0 files
C:\Dati\Sviluppo CREATOR OWNER:(OI)(CI)(IO)(F)
        THM\Svluppatori:(OI)(CI)(M)
        NT AUTHORITY\SYSTEM:(OI)(CI)(F)
        BUILTIN\Administrators:(OI)(CI)(F)

Successfully processed 1 files; Failed processing 0 files
C:\Dati\Marketing CREATOR OWNER:(OI)(CI)(IO)(F)
        THM\Marketing_Team:(OI)(CI)(M)
        NT AUTHORITY\SYSTEM:(OI)(CI)(F)
        BUILTIN\Administrators:(OI)(CI)(F)

Successfully processed 1 files; Failed processing 0 files
PS C:\Users\Administrator>
```

Figura 8: Output di `icacls` sulle tre cartelle. Sviluppo e Marketing risultano isolate e con ACL esplicite.

Legenda dei flag NTFS

Flag	Significato
(I)	Inherited — permesso ereditato dal container padre
(OI)	Object Inherit — il permesso si applica ai file figli

(CI)	Container Inherit — il permesso si applica alle sottocartelle
(IO)	Inherit Only — il permesso si applica solo agli eredi
(F)	Full Control
(M)	Modify
(RX)	Read & Execute

4.2 Esecuzione di programmi specifici

Per simulare un programma riservato al solo team tecnico ho creato la cartella C:\Tools e al suo interno uno script batch chiamato test-app.bat che stampa a video l'utente corrente. Sulla cartella Tools ho applicato lo stesso schema delle cartelle Dati: ereditarietà disabilitata, rimozione di BUILTIN\Users, aggiunta del gruppo Sviluppatori con permesso Read & Execute (senza Modify, perché il team non deve poter alterare gli eseguibili aziendali, solo lanciarli).

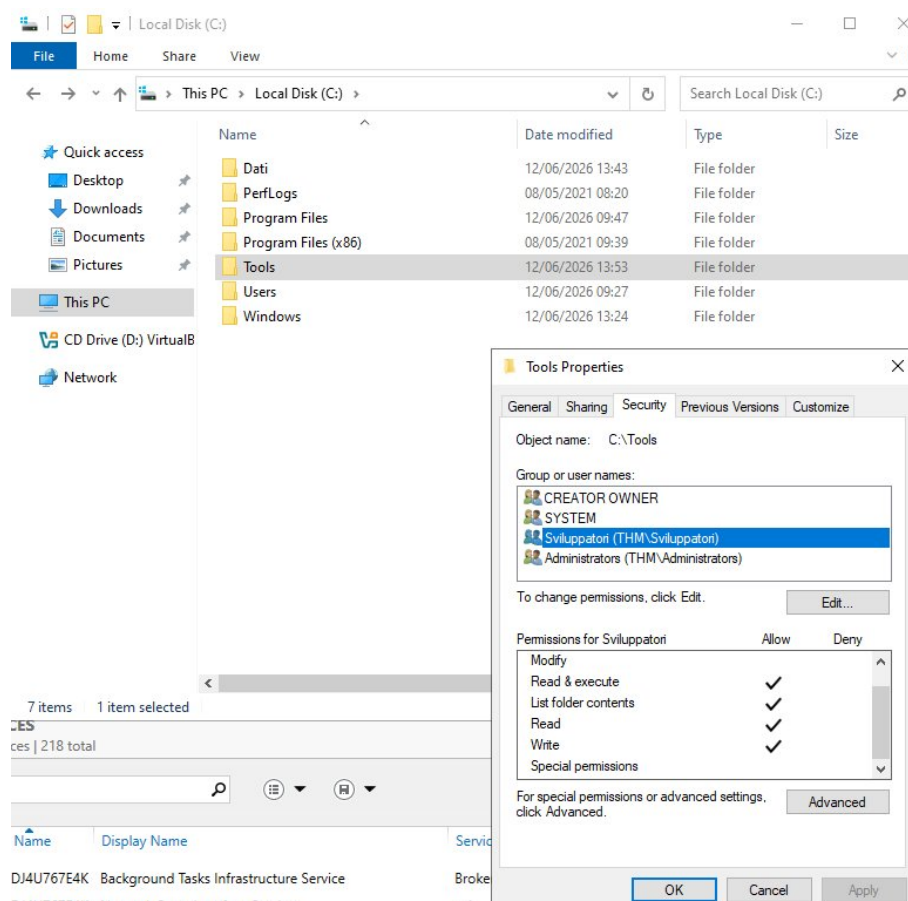


Figura 9: Tab Security di C:\Tools. Sviluppatori risulta presente con i soli permessi Read & Execute / List / Read.

4.3 Modifiche alle impostazioni di sistema

Per assegnare un privilegio amministrativo granulare al gruppo Sviluppatori ho scelto il diritto Change the system time, tipicamente concesso a chi si occupa di manutenzione del server. Tentando di assegnarlo da secpol.msc ho però incontrato la prima particolarità tecnica del laboratorio: i pulsanti Add User or Group e Remove risultavano disabilitati.

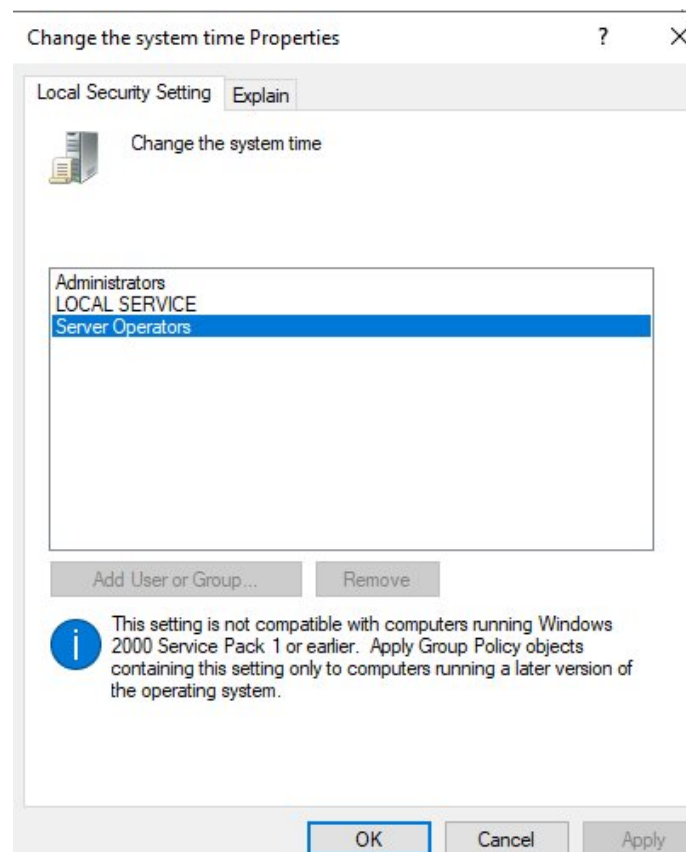


Figura 10: Local Security Policy in sola lettura sul Domain Controller. Pulsanti grigi e nota informativa di Windows.

Questo comportamento è by design: su un Domain Controller la Local Security Policy non è più gestibile localmente perché le impostazioni di sicurezza vengono distribuite centralmente tramite la GPO Default Domain Controllers Policy. La soluzione corretta è quindi aprire Group Policy Management, navigare fino alla policy del container Domain Controllers e modificare User Rights Assignment da lì.

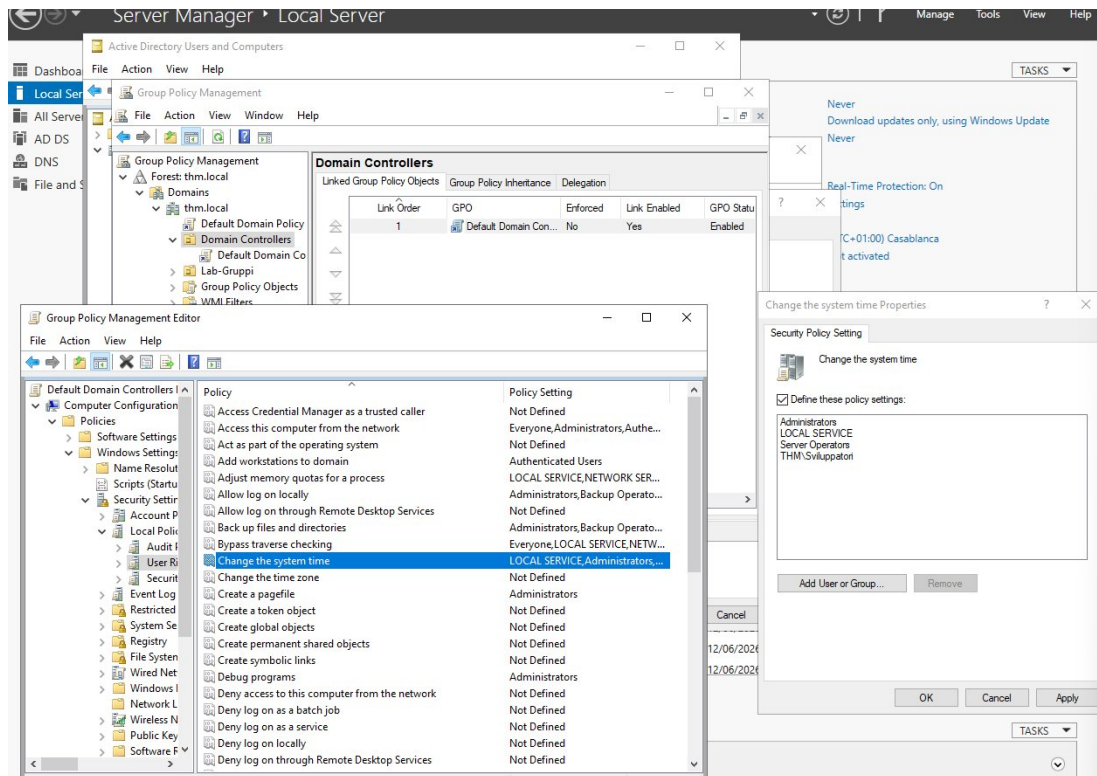


Figura 11: Group Policy Management Editor. Il diritto Change the system time include ora THM\Sviluppatori.

4.4 Accesso remoto al server

Ho abilitato Remote Desktop dal pannello Local Server di Server Manager, mantenendo attiva la Network Level Authentication per ragioni di sicurezza. Ho poi aggiunto il gruppo Sviluppatori al gruppo built-in Remote Desktop Users, in modo che tutti i membri del gruppo ereditassero automaticamente il diritto di connessione remota.

Tentando il primo accesso RDP con l'utente h.potter mi sono però trovato di fronte a un errore inatteso che ha richiesto un secondo intervento via GPO (vedi sezione Problemi riscontrati). Una volta concesso il diritto Allow log on through Remote Desktop Services al gruppo Sviluppatori tramite la stessa Default Domain Controllers Policy, l'accesso RDP ha cominciato a funzionare.

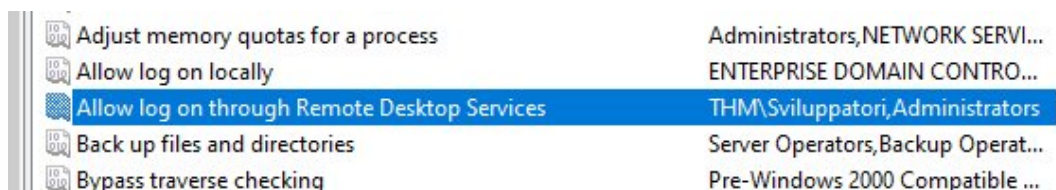


Figura 12: Vista finale della GPO User Rights Assignment. Allow log on through Remote Desktop Services include THM\Sviluppatori, Administrators.

4.5 Riepilogo dei permessi assegnati

Risorsa / Diritto	Sviluppatori	MarketingTeam	Motivazione
C:\Dati\Sviluppo	Modify	Nessuno	Spazio di lavoro tecnico riservato
C:\Dati\Marketing	Nessuno	Modify	Spazio di lavoro commerciale riservato
C:\Tools\test-app.bat	Read & Execute	Nessuno	Eseguibile aziendale per il solo team tecnico

Change the system time	Concesso (GPO)	Negato	Manutenzione sistema da parte del team tecnico
Remote Desktop	Concesso (GPO + RDU)	Negato	Solo gli amministratori tecnici accedono al server

Per validare la configurazione ho effettuato una sessione RDP dal mio host Windows verso il server, prima con le credenziali di h.potter (Sviluppatori) e poi con quelle di d.malfoy (MarketingTeam). Il confronto tra i due esiti rappresenta la vera prova del controllo degli accessi basato su gruppi.

5.1 Errore iniziale di Harry (pre-GPO RDP)

Il primo tentativo di login RDP di h.potter, nonostante l'utente fosse correttamente membro di Sviluppatori e di Remote Desktop Users, ha mostrato il seguente errore: To sign in remotely, you need the right to sign in through Remote Desktop Services. Si tratta di una restrizione specifica dei Domain Controller: il diritto Allow log on through Remote Desktop Services sul DC e concesso di default solo agli Administrators, indipendentemente dall'appartenenza a Remote Desktop Users.

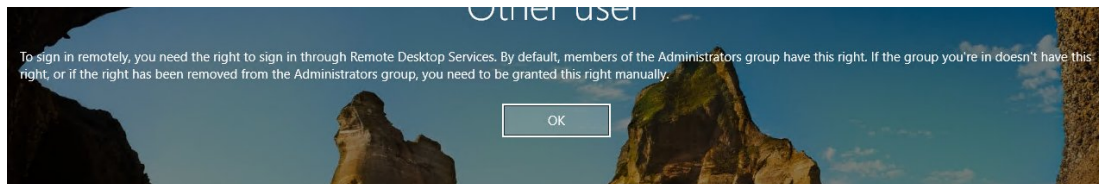


Figura 13: Errore iniziale di accesso RDP di h.potter, risolto poi tramite GPO (vedi sezione 6).

5.2 Verifica positiva di h.potter (post-GPO)

Dopo aver concesso il diritto al gruppo Sviluppatori e aver forzato l'aggiornamento delle policy (gpupdate /force), il login RDP di h.potter ha avuto successo. Nella sessione remota ho verificato contestualmente tutti i permessi attesi.

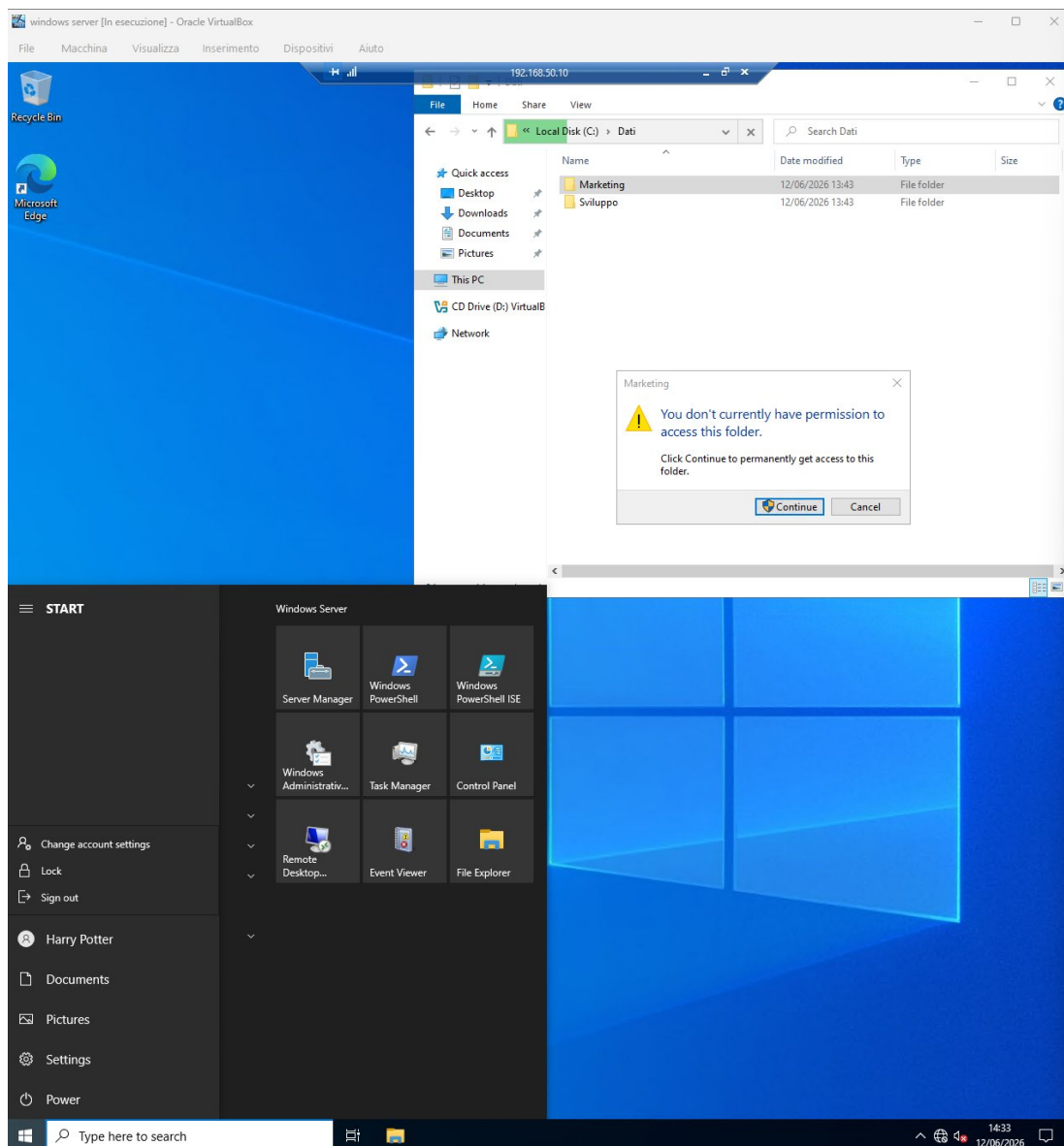


Figura 14: Sessione RDP attiva (titolo finestra 192.168.50.10) con identità Harry Potter. Accesso negato a Marketing, confermando la segmentazione.

Lo screenshot cattura tre evidenze in una sola immagine: il titolo della finestra mostra l'IP del server (sessione remota attiva), il menu Start riporta Harry Potter come utente loggato, e il tentativo di apertura di C:\Dati\Marketing produce il messaggio You don't currently have permission to access this folder. Il prompt offre l'opzione Continue per richiedere elevazione amministrativa, che ho deliberatamente rifiutato per non invalidare il test.

Ho poi confermato l'identità della sessione e l'appartenenza ai gruppi tramite `whoami /groups`:

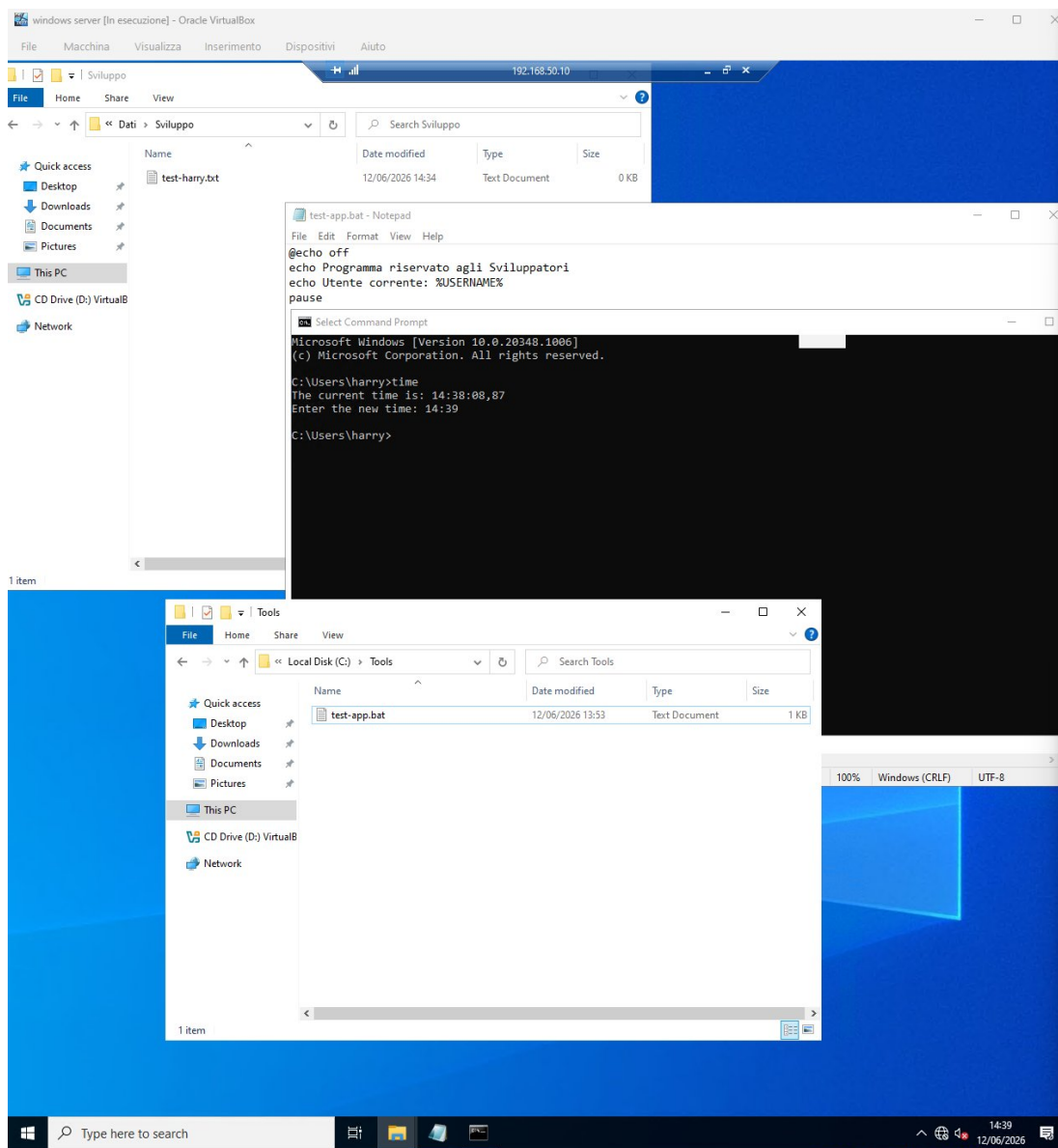


Figura 15: Output di `whoami /groups`. `THM\Sviluppatori` risulta tra i gruppi del token, insieme a `BUILTIN\Remote Desktop Users`.

L'output mostra il SID del gruppo `THM\Sviluppatori` e la presenza di `NT AUTHORITY\REMOTE INTERACTIVE LOGON`, che conferma a livello tecnico la natura RDP della sessione. Da notare anche `BUILTIN\Pre-Windows 2000 Compatible Access` con attributo `Group used for deny only`, particolarità di sicurezza Windows che impedisce l'uso di questo gruppo legacy per concedere permessi.

Ho poi verificato il permesso di scrittura sulla cartella di competenza e l'effettivo possesso del diritto `Change the system time`:

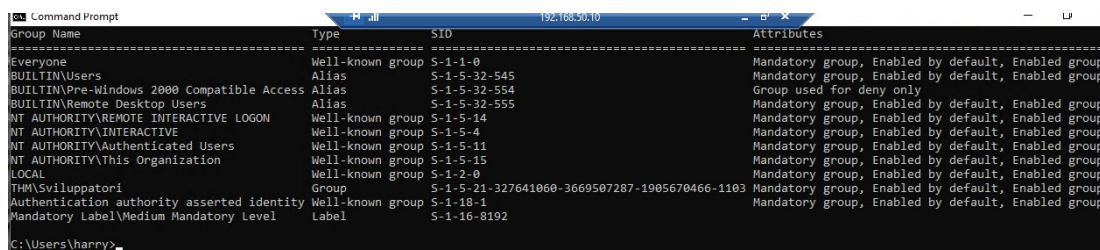


Figura 16: Creazione di `test-harry.txt` in `C:\Dati\Sviluppo` (Modify funzionante) e comando `time` accettato senza errori (SeSystemtimePrivilege attivo).

Per il diritto Change the system time il test più pulito non è l'interfaccia grafica Settings - Date and Time, che richiede elevazione UAC indipendentemente dal privilegio utente, ma il comando time da CMD, che invoca direttamente l'API SetSystemTime. L'accettazione del comando senza il messaggio A required privilege is not held by the client conferma il possesso effettivo del privilegio.

Infine ho verificato l'esecuzione del programma riservato:

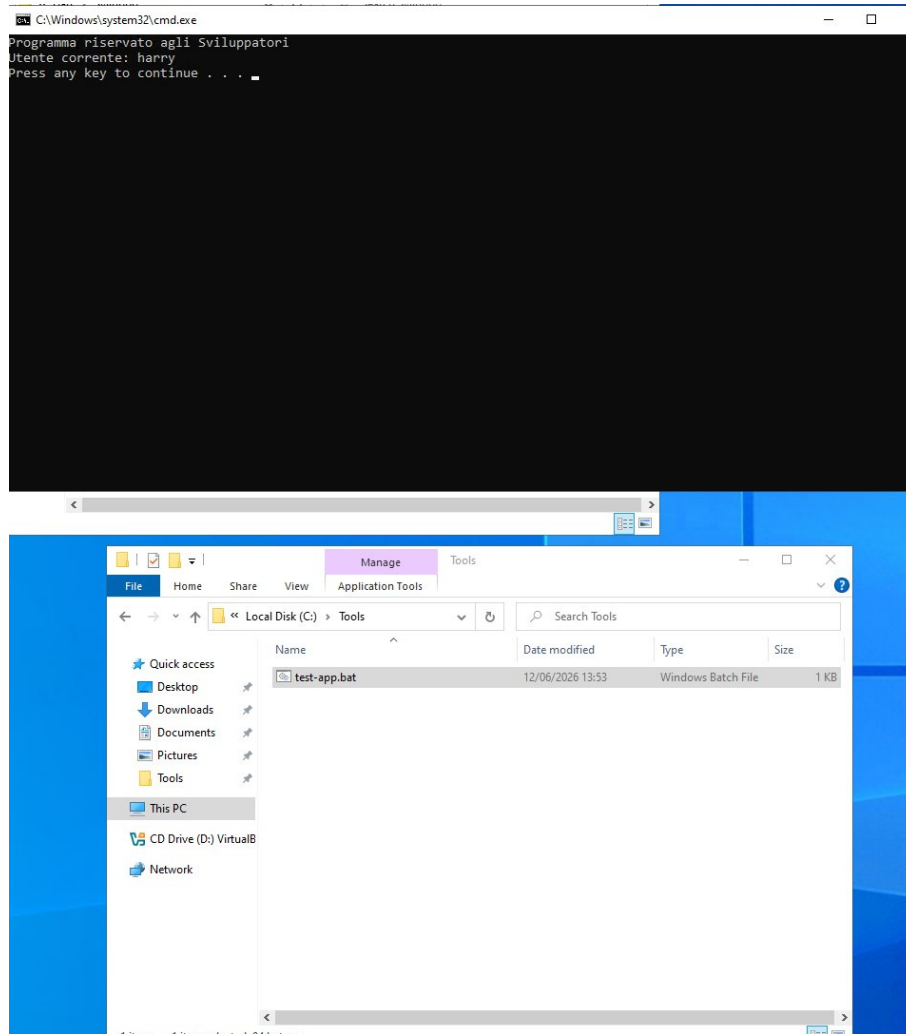


Figura 17: Esecuzione di test-app.bat da CMD nella sessione di Harry. L'output conferma il permesso Read & Execute su C:\Tools.

5.3 Controprova negativa di d.malfoy

Dopo aver chiuso la sessione di h.potter, ho avviato un nuovo tentativo di accesso RDP con le credenziali di d.malfoy. La connessione è stata rifiutata già a livello server con il messaggio The connection was denied because the user account is not authorized for remote login.

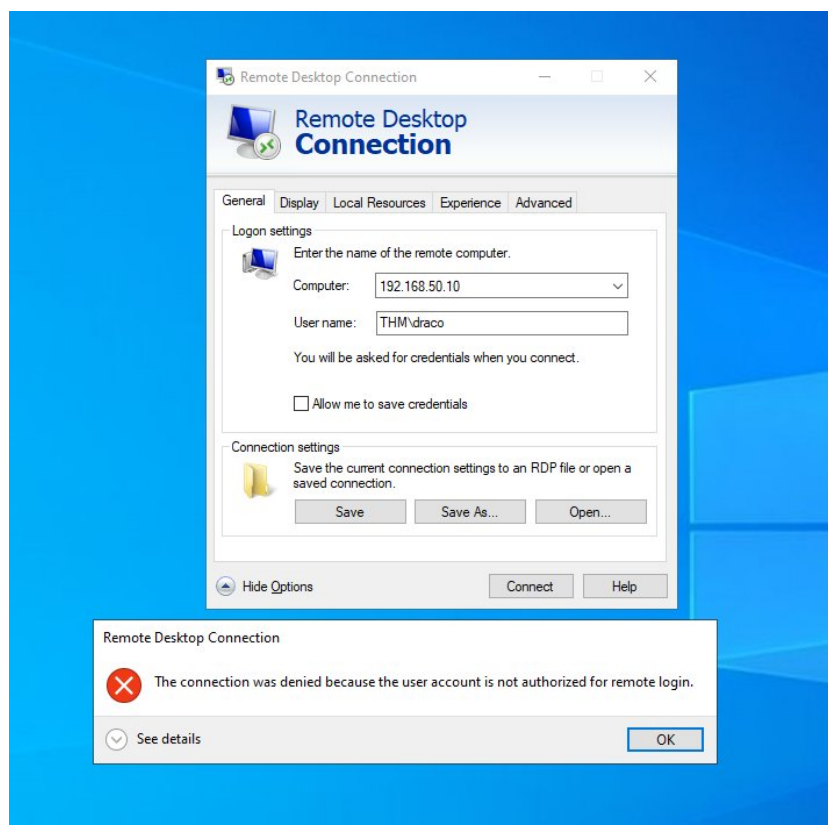


Figura 18: Tentativo di accesso RDP di d.malfoy. La connessione viene rifiutata a livello server.

Vale la pena sottolineare che l'errore ricevuto da d.malfoy è leggermente diverso da quello che aveva ricevuto h.potter prima dell'intervento GPO: nel caso di Harry l'errore arrivava dalla lockscreen del server (autenticazione riuscita, login negato dalla policy), mentre per Draco il rifiuto avviene a livello di connection, ovvero prima ancora che il server presenti la lockscreen, perché l'utente non appartiene al gruppo Remote Desktop Users. Questa differenza dimostra una difesa stratificata (defense in depth): il primo livello esclude gli utenti non abilitati già al perimetro della connessione, il secondo livello applica le politiche locali di login.

5.4 Matrice riassuntiva dei risultati

Test	h.potter (Sviluppatori)	d.malfoy (MarketingTeam)
Login RDP al server	Riuscito	Connection denied
Accesso C:\Dati\Sviluppo	OK (Modify)	Access Denied atteso
Accesso C:\Dati\Marketing	Access Denied	OK (Modify) atteso
Esecuzione test-app.bat	Eseguito	Negato atteso
Comando time	Accettato	Bloccato atteso

I test contrassegnati come atteso per d.malfoy non sono stati eseguiti direttamente sul server perché l'utente non è riuscito ad accedervi via RDP, né avrebbe potuto loggarsi alla console locale: su un Domain Controller il diritto Allow log on locally è limitato per default agli operatori privilegiati. Il blocco al perimetro RDP costituisce comunque la prima e più importante linea di difesa, e la sua corretta applicazione è di per sé prova del funzionamento della segregazione basata su gruppi.

Il laboratorio ha presentato alcune particolarità tecniche che ho dovuto risolvere strada facendo. Le documento qui sia per trasparenza, sia perché rappresentano nozioni utili in ottica amministrazione sistemi Windows in dominio.

6.1 Local Security Policy in sola lettura sul DC

Cosa: i pulsanti per modificare User Rights Assignment in secpol.msc risultavano grigi. Perché: sul Domain Controller la sicurezza locale viene ereditata interamente dalla GPO Default Domain Controllers Policy; la console locale è quindi un visualizzatore in sola lettura. Soluzione: ho gestito tutte le User Rights Assignment dall'editor della GPO di dominio, quindi con un `gpupdate /force` per applicarle senza attendere il refresh periodico.

6.2 RDP negato a h.potter nonostante Remote Desktop Users

Cosa: l'utente h.potter, pur essendo membro di Sviluppatori e del gruppo built-in Remote Desktop Users, riceveva l'errore `you need the right to sign in through Remote Desktop Services`. Perché: sul Domain Controller il diritto `Allow log on through Remote Desktop Services` non è implicito nell'appartenenza a Remote Desktop Users, ma deve essere assegnato esplicitamente tramite GPO. È una misura di hardening Microsoft tesa a evitare che utenti standard possano collegarsi alla console di un DC. Soluzione: ho aggiunto THM\Sviluppatori a quella User Rights Assignment, mantenendo Administrators per non sbloccare l'accesso amministrativo legittimo.

6.3 Doppia estensione nascosta sul file batch

Cosa: il file creato come `test-app.bat` da Explorer appariva con tipo `Text Document` e non veniva eseguito da CMD (`not recognized as an internal or external command`). Perché: Windows nasconde di default le estensioni dei file conosciuti; rinominando `New Text Document.txt` in `test-app.bat` il file veniva in realtà salvato come `test-app.bat.txt`. Soluzione: ho attivato in Explorer l'opzione `File name extensions` (tab `View`) e rinominato il file rimuovendo il `.txt` residuo. Implicazione di sicurezza: la stessa logica è alla base di un classico vettore di social engineering, dove un eseguibile malevolo viene mascherato da documento (es. `report.pdf.exe`); su un server amministrativo l'estensione completa deve essere sempre visibile.

6.4 UAC su Settings - Date and Time

Cosa: nonostante h.potter avesse ricevuto il diritto `Change the system time`, l'interfaccia grafica `Settings - Date and Time` richiedeva comunque credenziali amministrative. Perché: il modulo `Settings` ha bisogno di elevazione UAC a livello di processo per modificare il pannello, indipendentemente dal possesso del privilegio utente. Il diritto opera a livello di API kernel (`SetSystemTime`) non a livello di UI. Soluzione: ho verificato il diritto tramite il comando `time` in CMD non elevata, che invoca direttamente l'API. La mancanza del messaggio di errore `A required privilege is not held by the client` ha confermato che il privilegio era effettivamente presente nel token di h.potter.

L'esercizio mi ha permesso di mettere in pratica in modo concreto il principio del minimo privilegio applicato a un dominio Active Directory. La distinzione tra gruppi `Security` e gruppi `Distribution`, tra gestione locale e gestione GPO, tra diritti utente granulari e gruppi built-in, è diventata molto più chiara grazie ai problemi tecnici incontrati lungo il percorso, in particolare la lettura obbligatoria della `Default Domain Controllers Policy` per qualsiasi modifica di sicurezza su un DC.

Il setup finale rispecchia uno scenario aziendale realistico: due team con esigenze operative diverse, ciascuno con accesso ai propri spazi di lavoro e separato dagli altri, con privilegi di manutenzione concessi solo al gruppo tecnico, e con un singolo punto di amministrazione centralizzato (la GPO di dominio) che permette di estendere o restringere i privilegi senza intervenire su ogni singolo utente. Questo è esattamente il valore aggiunto di Active Directory rispetto alla gestione locale dei gruppi: la

scalabilità del controllo accessi.

Una considerazione di sicurezza che emerge dall'esperienza: in produzione, l'accesso RDP diretto a un Domain Controller dovrebbe essere evitato o limitato a jump host dedicati. Per il laboratorio l'ho abilitato per motivi didattici e per disporre di una via di verifica realistica, ma in un ambiente reale avrei preferito esporre il DC esclusivamente attraverso strumenti di amministrazione remota (RSAT) installati su workstation amministrative dedicate.